



PARTNER GATEWAY SDK

VERSION 1

DEVELOPER REVIEW • NOT FOR PRODUCTION USE

A reusable, secure membership-verification hand-off for
TouristSaver strategic partners.

Prepared for
Experience Oz and future TouristSaver strategic partners

5 July 2026

Contents

- 1** Executive summary
- 2** Member journey
- 3** Responsibility model
- 4** V1 developer package
- 5** Quick integration example
- 6** SDK configuration
- 7** Runtime behaviour and errors
- 8** Required TouristSaver backend APIs
- 9** Partner registry and scale
- 10** Security and privacy model
- 11** Experience Oz demonstration
- 12** Acceptance testing
- 13** Production readiness checklist
- 14** Current status and next step

1. Executive summary

The TouristSaver Partner Gateway is the standard mechanism through which a strategic partner can verify that a visitor has an active TouristSaver membership before granting access to a member-exclusive partner page.

Experience Oz is the first proposed implementation. The gateway is deliberately partner-neutral so the same SDK and API contract can support future partners including eSIM providers, accommodation operators, attractions, transport providers, insurers, vehicle hire companies, cruise operators, and international white-label partners.

The package is ready for architecture and developer review. It is not ready to install in production. TouristSaver must first implement the token-issuance and verification APIs, configure the partner registry, and host an immutable production SDK asset.

What the gateway does

- Confirms that a visitor arrived with a valid, active TouristSaver membership hand-off.
- Protects the intended entry path to a member-exclusive partner landing page.
- Removes the short-lived token from the browser address bar.
- Fails closed when a token is missing, invalid, expired, mismatched, or cannot be verified.
- Redirects unauthorised visitors to a configured TouristSaver landing page.
- Gives every partner the same small integration surface.

What the gateway does not do

- Product or inventory management
- Pricing or discount calculation
- Booking integration
- Checkout or payment processing
- Partner customer accounts
- Customer fulfilment or support

The partner remains fully responsible for its website, products, pricing, booking journey, checkout, and fulfilment.

2. Member journey

1. A signed-in member selects a strategic partner inside TouristSaver.
2. TouristSaver verifies the member's active membership.
3. TouristSaver issues a short-lived, partner-specific hand-off token.
4. TouristSaver opens the approved partner URL with `ts_token` attached.
5. The Partner Gateway SDK removes the token from the address bar.

6. The SDK asks the TouristSaver verification API to validate the token.
7. If valid, the existing partner page is revealed without changing its behaviour.
8. If invalid or unavailable, the visitor is redirected to TouristSaver with a clear member-only message.

TouristSaver App

- > membership verification
- > short-lived partner token
- > protected partner URL
- > Partner Gateway verification
- > allow existing page OR redirect to TouristSaver

3. Responsibility model

TouristSaver responsibilities

- Member authentication
- Active-membership verification
- Partner registration and activation
- Secure token issuance
- Central token verification
- Member-only fallback landing page
- SDK versioning and production hosting
- Gateway monitoring and privacy-minimised audit records

Partner responsibilities

- Include and configure the versioned SDK on the protected landing page.
- Retain ownership of products, pricing, bookings, checkout, and fulfilment.
- Use HTTPS and an appropriate Content Security Policy.
- Prevent tokens entering analytics, logs, or error-monitoring breadcrumbs.
- Complete the common TouristSaver acceptance test suite.
- Apply server- or edge-side enforcement if genuinely sensitive content is protected.

4. V1 developer package

The hand-off package contains:

- `touristsaver-partner-gateway.js` — dependency-free browser SDK

- README.md — package overview and quick start
- docs/INSTALLATION.md — production integration checklist
- docs/CONFIGURATION.md — complete setting reference
- docs/API.md — issuance and verification REST contract
- docs/ARCHITECTURE.md — scalable platform architecture
- docs/SECURITY.md — trust boundary and production controls
- examples/experience-oz.html — proposed first-partner implementation
- examples/test-page.html — standalone local acceptance page
- examples/error-handling.html — callbacks and browser events
- examples/unauthorised.html — safe fallback-message rendering
- test/gateway.test.js — automated SDK behaviour tests

The SDK is approximately 10 KB unminified and has no runtime dependencies.

5. Quick integration example

Place the SDK and its configuration at the beginning of the protected page's <head> so access is checked before partner content is shown.

```
<meta name="referrer" content="no-referrer" />

<script src="/assets/touristsaver-partner-gateway.v1.0.0.js"></script>

<script>

  TouristSaverGateway.init({

    partner: 'experienceoz',

    verifyEndpoint:

      'https://api.touristsaver.org/api/partner-gateway/verify-token',

    redirectUrl:

      'https://touristsaver.org/partners/experienceoz',

    unauthorisedMessage:

      'This offer is exclusively available to TouristSaver members.'

  });

</script>
```

No URL is hard-coded inside the SDK. TouristSaver supplies each approved partner with its slug, endpoint, fallback URL, test origins, and production origins.

6. SDK configuration

Required settings

partner

The registered lowercase partner slug. It is the token audience and must match the value held in the TouristSaver partner registry.

verifyEndpoint

The TouristSaver REST endpoint used to validate the hand-off token. Production endpoints must use HTTPS.

redirectUrl

The TouristSaver landing page used when access is denied or cannot be verified.

Optional settings

unauthorisedMessage

Public fallback text. Default: "This offer is exclusively available to TouristSaver members."

tokenParameter

Query-string token name. Default: ts_token.

requestTimeoutMs

Verification timeout from 1–30 seconds. Default: 8000 milliseconds.

blockPage

Prevents the partner page flashing before an access decision. Default: true.

persistTokenInSession

Allows same-tab refresh while the short-lived token remains valid. Default: true.

includeMessageInRedirect

Adds the configured message to the fallback URL. Default: true.

onAuthorised / onUnauthorised

Optional callbacks containing safe operational metadata only. Tokens and member PII are never returned.

7. Runtime behaviour and errors

The SDK reads `ts_token`, immediately removes it from browser history, and submits it with the configured partner slug to TouristSaver. A successful response must state both `valid: true` and the same partner slug.

The SDK recognises these denied-access reasons:

- `missing_token`
- `invalid_token`
- `expired_token`
- `partner_mismatch`
- `partner_inactive`
- `membership_inactive`
- `verification_unavailable`

Every failure path is fail-closed. A network problem never reveals the partner page.

The fallback redirect adds `ts_gateway_reason` and, by default, `ts_gateway_message`. Landing pages must render the message as escaped text, never raw HTML.

The SDK also dispatches `touristsaver:authorised` and `touristsaver:unauthorised` browser events for safe operational monitoring.

8. Required TouristSaver backend APIs

These endpoints are proposed contracts and are not live yet.

Issue a partner token

POST `/api/partner-gateway/token`

Authorization: Bearer `<member-access-token>`

Content-Type: `application/json`

Request:

```
{  
  
  "partner": "experienceoz"  
}
```

Successful response:

```
{  
  
  "token": "pg_opaque_random_value",  
  
  "partner": "experienceoz",  
  
  "expiresAt": "2026-07-05T04:32:00Z",  
  
  "launchUrl": "https://touristsaver.experienceoz.com.au/?ts_token=pg_opaque_random_value",  
  
  "requestId": "pgreq_01JZ..."  
}
```

The authenticated issuance service must verify active membership, verify the partner is active, generate at least 128 bits of cryptographically secure randomness, and build the launch URL from the server-side registry.

Verify a partner token

POST /api/partner-gateway/verify-token

Content-Type: application/json

X-TouristSaver-Gateway-Version: 1.0.0

Origin: https://touristsaver.experienceoz.com.au

Request:

```
{  
  
  "token": "pg_opaque_random_value",  
  
  "partner": "experienceoz",  
  
  "sdkVersion": "1.0.0"  
}
```

Valid response:

```
{  
  
  "valid": true,  
  
  "partner": "experienceoz",  
  
  "expiresAt": "2026-07-05T04:32:00Z",  
}
```



```
"requestId": "pgreq_01JZ..."

}
```

Expected denied response:

```
{

  "valid": false,

  "reason": "expired_token",

  "requestId": "pgreq_01JZ..."

}
```

Expected access decisions use HTTP 200. Malformed requests use 400, rate limiting uses 429, and infrastructure outages use 503. Any transport failure is treated as `verification_unavailable`.

9. Partner registry and scale

The gateway is designed for a future estate of 100 or more partners. New partners are data and configuration, not new SDK branches.

Each registry record should contain:

- Stable partner slug
- Active status
- Display name
- Approved protected launch URL
- Exact allowed browser origins
- TouristSaver fallback URL
- Token lifetime policy

Recommended backend components are a primary partner registry, authenticated issuance service, short-TTL token-digest store, stateless verification service, exact-origin CORS middleware, rate limiting, and privacy-minimised gateway metrics.

10. Security and privacy model

The TouristSaver API is authoritative. The SDK never decodes a token or decides membership status locally.

Recommended V1 controls:

- Opaque, random, partner-bound tokens with a maximum two-minute lifetime
- SHA-256 token digests at rest; never raw token storage or logging
- Exact partner-origin CORS allowlists; never wildcard CORS
- HTTPS and HSTS on all production hosts
- Cache-Control: no-store on issuance and verification responses
- Rate limits by source, partner, and token digest
- Constant-time digest comparison
- No member PII in verification responses
- Launch and fallback URLs sourced only from the partner registry
- Referrer-Policy: no-referrer on protected pages
- Versioned immutable SDK assets with Subresource Integrity where supported
- Explicit ts_token redaction in analytics and error tooling

Important browser boundary

The SDK protects the intended access journey but cannot make HTML already delivered to a browser cryptographically private from someone who disables JavaScript. Sensitive inventory, private pricing APIs, or privileged operations require the same TouristSaver verification contract to be enforced at the partner's server or edge before establishing a first-party partner session.

11. Experience Oz demonstration

The proposed Experience Oz page is touristsaver.experienceoz.com.au. The example adds the generic SDK and the experienceoz partner configuration only.

It does not change:

- Experience Oz products or catalogue
- Pricing or TouristSaver benefit rules
- Booking workflow
- Checkout or payment processing
- Customer accounts
- Fulfilment

After successful gateway verification, the existing Experience Oz page and booking journey continue normally.

12. Acceptance testing

The partner and TouristSaver teams should jointly confirm:

1. A valid Experience Oz token reveals the unchanged partner page.
2. A missing token redirects to TouristSaver.
3. An invalid token redirects to TouristSaver.
4. An expired token redirects to TouristSaver.
5. A token issued for another partner is rejected.
6. A network timeout or API outage fails closed.
7. The token disappears from the address bar immediately.
8. Same-tab refresh revalidates while the token remains unexpired.
9. Browser console, analytics, and logs contain no token or member PII.
10. No product, pricing, booking, checkout, or fulfilment behaviour changes.

The supplied automated suite currently validates seven core SDK behaviours: valid access, missing token, expiry, partner mismatch, network failure, same-tab revalidation, and unsafe endpoint configuration.

13. Production readiness checklist

TouristSaver must complete

- Implement authenticated token issuance.
- Implement the central verification endpoint.
- Create and operate the partner registry.
- Configure exact Experience Oz sandbox and production origins.
- Host the versioned SDK on an approved production asset service.
- Provide fallback landing-page message handling.
- Establish monitoring, redaction, rate limits, and operational ownership.
- Complete security review and end-to-end acceptance testing.

Experience Oz must review

- Proposed SDK placement and configuration.
- Content Security Policy and referrer policy.
- Production and sandbox origins.
- Token redaction in analytics and operational tooling.
- Whether browser-level gating is sufficient for the proposed page.
- Joint acceptance and outage behaviour.

14. Current status and next step

Ready now: Generic SDK V1 source, documentation, proposed API contract, Experience Oz example, local test page, error examples, and automated tests.

Not ready yet: Live API endpoints, production partner registry, production SDK hosting, production origins, operational monitoring, and end-to-end production approval.

The recommended next step is a joint architecture review between TouristSaver and the Experience Oz development team. Once the contract and security boundary are agreed, TouristSaver can schedule backend implementation and provide a sandbox integration environment.

TouristSaver Partner Gateway SDK V1

External developer review package — not for production installation